



Important note: Each of these propagation mechanisms depend on the system vulnerability that's exploited, since this dictates what system rights are enjoyed by the attackers.

After the construction of the attack network, attackers use attack tool-kits to specify the attack type and the victim's address, and wait for the appropriate moment in order to mount the attack. They then remotely command the launch of the chosen attack to their zombies, using the attack tool-kit, to begin the attack.

The volume of traffic from a DDoS attack may be so high that the networks that connect the attacking machines to the victim may also suffer from lower performance. Hence, the provision of services over these networks is no longer possible, and in this way, their clients are denied those services.

Attack tool-kits

While there are numerous scripts that are used for scanning, compromising and infecting vulnerable machines, there are only a handful of DDoS attack tools that have been used to carry out the actual attacks.

Trinoo

This tool uses a handler/agent architecture wherein an attacker sends commands to the handler (the first system compromised in the series) via TCP, and handlers and agents communicate via UDP. Both handlers and agents are password-protected to try to prevent them from being taken over by another attacker. Trinoo generates UDP packets of a given size to random ports on one or multiple target addresses, during a specified attack interval.

Tribe Flood Network (TFN)

This tool uses a different type of handler/agent architecture. Commands are sent from the handler to all of the agents, from the command line. The attackers do not 'log in' to the handler as with Trinoo. This tool can perform a UDP flood, a TCP SYN flood and Smurf attacks at specified or random victim ports. The attackers run commands from the handler using any of a number of connection methods (e.g., a remote shell bound to a TCP port, and UDP-based client/server remote shells). All commands sent from the handler to agents through ICMP packets are encoded, which hinders detection.

Tribe Flood Network 2000 (TFN2K)

An improved version of TFN, this includes several features designed specifically to make its traffic difficult to recognise and filter; to remotely execute commands; to obfuscate the true source of the traffic, and to transport TFN2K traffic over multiple transport protocols, including UDP, TCP, and ICMP. TFN2K obfuscates the true traffic source by spoofing source addresses.

Trinity

This is the first DDoS tool that is controlled via IRC. Upon compromise and infection by Trinity, each zombie joins a

specified IRC channel and waits for commands. The use of a legitimate IRC service for communication between attacker and zombie replaces the classic independent handler, and elevates the level of the threat. It is also capable of launching several types of flooding attacks on a victim site, including UDP, an IP fragment, TCP SYN, TCP RST, TCP ACK, and other floods.

Now, due to regular security checks and patches, and signature-based IDS/IPS (Intrusion Detection/Prevention Systems), many of these tools have become less effective, and are not used by attackers. However, this has led to the next era of DDoS attacks, which is referred to as DDoS 2.0.

DDoS 2.0

Network firewalls today can detect the majority of flood and network DoS attacks. Many ICMP and UDP flood attacks can also be identified using intelligent packet filtering, and source and destination access-control lists. Hence, attackers today focus on application DDoS attacks, because these usually bypass most traditional network security devices.

Application DDoS attacks exploit vulnerabilities in application servers or application business logic. For example, application DDoS attacks may simply flood a Web application server with seemingly legitimate requests designed to overwhelm Web application servers. An attacker may also attempt to exploit application vulnerabilities, such as sending Web requests with extremely long URLs. More sophisticated attacks exploit business logic flaws. For example, if an application's website search mechanism is poorly written, it could require excessive processing by a back-end database server. An application DDoS attack could exploit this vulnerability by performing thousands of search requests using wild-card search terms to overwhelm the back-end application database. Moreover, the generation of session IDs, and the resources used to manage sessions, can often be overwhelmed if an attacker has the ability to generate a large number of session IDs.

Recently, 'Slowloris' has emerged as a perilous application DDoS attack. It disrupts application services by exhausting Web server connections. In the Slowloris attack, the attackers send an incomplete HTTP header, and then periodically send header lines to keep the connection alive, but they never send the full header. Without requiring that much bandwidth, an attacker can open numerous connections, and overwhelm the targeted Web server. While multiple patches have been created for Apache to mitigate this vulnerability, it nonetheless demonstrates the power of more sophisticated DDoS attacks.

What makes DDoS 2.0 different?

DDoS attacks are traditionally carried out by computer-based bots. DDoS 2.0 is considered to be a highly amplified class of DDoS attacks. Recently, a new breed of DDoS attacks has been uncovered that uses Web servers as payload-carrying bots. Using a basic software program equipped with a